TECHNICAL AUDIT & PORTFOLIO SHOWCASE

SISTEM INFORMASI & PENDAFTARAN PASIEN RUMAH SAKIT ONLINE

Laporan Analisis Arsitektur Rekayasa Perangkat Lunak, Evaluasi Skema Basis Data Relasional, Audit Celah Keamanan Siber (Vulnerability Assessment), dan Lembar Portofolio Profesional Full-Stack Web Development.

RINGKASAN INTI DOKUMEN

Dokumen ini menyajikan evaluasi mendalam terhadap aplikasi web **RS Online (Tugas Besar)** yang dirancang untuk memodernisasi registrasi pasien dan penyebaran informasi fasilitas kesehatan. Dilengkapi dengan evaluasi struktural, pemodelan data normalisasi, pembuktian risiko keamanan (SQL Injection, CSRF, Access Control), rekomendasi refaktorisasi PDO berstandar industri, serta portofolio kompetensi rekayasa.

PENGEMBANG / AUTHOR
Yoginara Pratama Sitorus

ROLE / SPESIALISASI
Full-Stack Web Developer & Engineer

KLASIFIKASI PROYEK
Web Application (Healthcare Portal & CRUD)

STATUS & KESIAPAN
Functional Prototype & Production Roadmap

STACK TEKNOLOGI INTI:

PHP 8.x Native | MySQL / MariaDB 10.4 | Bootstrap 5.1 & 5.3 | JavaScript ES6 | HTML5 & CSS3 | Apache HTTP Server | Git Version Control

Repository: **Tugas_Besar / RS Online** | Audit Keamanan & Rencana Skalabilitas

Versi 2.0 (Audit & Portfolio Edition)

1. Ringkasan Eksekutif & Lembar Portofolio Profesional

RS Online adalah platform sistem informasi manajemen pendaftaran pasien berbasis web yang dikembangkan untuk mengatasi kendala antrean panjang pendaftaran tatap muka di rumah sakit. Melalui sistem ini, calon pasien dapat mendaftarkan identitas, data kontak, dan gejala klinis secara mandiri dari smartphone atau komputer, sementara staf administrasi rumah sakit memperoleh dashboard terpusat untuk mengelola, mencari, memperbarui, dan menghapus data kunjungan secara real-time.

100%	3 Kolom	Responsive	Modular
FUNGSIONALITAS CRUD	PENCARIAN TERPADU	BOOTSTRAP 5 UI	FUNCTIONS REPOSITORY

1.1 Nilai Utama & Fitur Unggulan Sistem

1. Portal Profil & Edukasi Medis

Menyediakan informasi komprehensif terkait sejarah rumah sakit, divisi pelayanan darurat (UGD), fasilitas rawat inap, integrasi dokter spesialis (IDI), serta peta persebaran jaringan fasilitas kesehatan nasional.

2. Intake Pendaftaran Pasien Mandiri

Formulir digital dengan validasi antarmuka untuk mencatat nama lengkap, tempat/tanggal lahir, jenis kelamin, kontak (telepon & email), dan keluhan awal penyakit tanpa perlu datang langsung.

3. Dashboard Admin & Data Pasien

Tabel visual terstruktur yang dilengkapi pewarnaan kontekstual Bootstrap, penomoran berurutan otomatis, aksi manipulasi record instan (Edit/Delete) dengan modal konfirmasi interaktif.

4. Mesin Pencari Multi-Parameter

Kemampuan pencarian fleksibel menggunakan operator `LIKE` yang memindai secara simultan pada tiga kolom sekaligus: Nama Pasien, Jenis Penyakit (Gejala), dan Jenis Kelamin.

1.2 Visualisasi Fasilitas & Jaringan Nasional

Pelayanan Medis	Layanan Darurat	Rawat Inap	Pendaftaran Daring
Konsultasi dokter umum & spesialis terpadu.	Unit gawat darurat siaga 24 jam setiap hari.	Kamar perawatan modern & terhubung nasional.	Registrasi mandiri dari smartphone & PC.

PETA JARINGAN RUMAH SAKIT MITRA DI INDONESIA:



2. Arsitektur Sistem & Pemetaan File

Aplikasi dibangun menggunakan model prosedural terpusat dengan modul helper (`functions.php`) sebagai penghubung akses data. Pola ini memisahkan logika kueri SQL dasar dari skrip antarmuka tampilan.

2.1 Struktur Direktori Proyek

```
D:\data c
s\Tugas_Besar├── content│   ├── index.php          # Portal informasi sejarah, visi misi & dokter
│   ├── style.css          # Styling kustom konten & background jumbotron
│   └── tentang.php        # Detail layanan, peta jaringan RS & kontak
├── database│   └── pendaftaran.sql     # Skrip migrasi DDL & sample data tabel datapasien
├── image\                 # Direktori aset grafis (Logo, Icon layanan, Map, Banner)
├── profile│   ├── index.php          # Landing page utama (Hero section & quick actions)
│   └── style.css          # Styling hero jumbotron & responsive layout
├── functions.php          # Modul inti koneksi DB & pembungkus fungsi CRUD
├── index.php              # Halaman utama manajemen data pasien (Admin Table)
├── tambah.php             # Formulir registrasi pasien mandiri
├── ubah.php               # Formulir pembaruan data rekam pasien
├── hapus.php              # Endpoint pengendali proses penghapusan data
└── style.css              # Pengaturan background wallpaper global
```

2.2 Peta Alur Pengguna (User Journey Flow)

1. Home Portal `profile/index.php` Pintu navigasi awal. → **2. Profil & Layanan** `content/tentang.php` Eksplorasi poli & lokasi. → **3. Registrasi** `tambah.php` Pengisian form pasien. → **4. Kelola Rekam** `index.php` Tinjau, cari, edit, hapus.

2.3 Dekonstruksi Logika Backend (`functions.php`)

Nama Fungsi	Parameter & Return	Mekanisme & Logika Kerja
`query($query)`	Param: `string` Return: `array`	Mengeksekusi kueri SELECT via `mysqli_query`, melakukan perulangan `mysqli_fetch_assoc`, dan mengembalikan kumpulan baris dalam bentuk matriks *associative array*.
`tambah($data)`	Param: `array $_POST` Return: `int (affected rows)`	Menerima data form, melakukan sanitasi karakter via `htmlspecialchars()`, lalu menyusun kueri INSERT ke tabel `datapasien`. Mengembalikan 1 jika sukses, -1 jika gagal.
`hapus($id)`	Param: `int $id` Return: `int (affected rows)`	Mengeksekusi kueri SQL `DELETE FROM datapasien WHERE id=$id` berdasarkan ID yang ditransmisikan melalui URL query parameter.
`ubah($data)`	Param: `array $_POST` Return: `int (affected rows)`	Mengambil input form termasuk ID tersembunyi (hidden input), memperbarui seluruh atribut pasien pada kueri `UPDATE`, dan mengembalikan status baris terdampak.
`cari($keyword)`	Param: `string $keyword` Return: `array`	Membangun klausa `WHERE ... LIKE '%keyword%'` untuk mencocokkan kemiripan substring pada kolom `Nama_Pasien`, `Jenis_Penyakit`, dan `Jenis_Kelamin`.

3. Desain Basis Data & Analisis Normalisasi

Aplikasi memanfaatkan sistem basis data relasional **MariaDB / MySQL** dengan database `pendaftaran` dan tabel utama `datapasien`.

3.1 Kamus Data (Data Dictionary) - Tabel `datapasien`

Nama Kolom	Tipe Data	Null	Kunci	Default	Deskripsi & Integritas Data
id	INT(11)	NO	PRIMARY	AUTO_INC	Pengidentifikasi unik setiap rekaman pasien pendaftar.
Nama_Pasien	VARCHAR(50)	NO	-	None	Nama lengkap calon pasien (maksimal 50 karakter).
Tempat_dan_Tanggal_Lahir	VARCHAR(50)	NO	-	None	Data tempat dan tanggal kelahiran (format bebas / unformatted text).
Jenis_Kelamin	VARCHAR(20)	NO	-	None	Gender pasien (Laki-Laki / Perempuan).
Nomor_Telepon	VARCHAR(50)	NO	-	None	Kontak nomor ponsel atau saluran darurat pasien.
Email	VARCHAR(50)	NO	-	None	Alamat pos-el untuk konfirmasi jadwal konsultasi.
Jenis_Penyakit	VARCHAR(20)	NO	-	None	Gejala klinis atau keluhan awal yang dialami pasien.

3.2 Evaluasi Normalisasi & Rekomendasi Skema 3NF

Temuan Analisis Normalisasi:

- **Pelanggaran 1NF pada Kolom Kelahiran:** Atribut `Tempat_dan_Tanggal_Lahir` menyimpan dua informasi diskrit dalam satu string (contoh: `"Bali,03 September 2007"`), menyulitkan kalkulasi usia, pengelompokan demografi, atau sorting kronologis.
- **Ketiadaan Entitas Kunjungan:** Pasien yang mendaftar ulang akan menduplikasi seluruh informasi profilnya, menimbulkan redundansi data pribadi.

Rekomendasi Arsitektur Database Enterprise (3NF):

Tabel Entitas	Atribut Kunci	Hubungan Relasi (Relationship)	Keuntungan Arsitektural
pasien	`id_pasien (PK)`, nik, nama_lengkap, tempat_lahir, tgl_lahir (DATE), gender, telepon, email	1-to-Many dengan tabel `pendaftaran`	Pencatatan profil pasien permanen tanpa duplikasi identitas saat kunjungan ulang.
dokter	`id_dokter (PK)`, nama_dokter, spesialisasi, id_poli (FK), no_sip	1-to-Many dengan `pendaftaran` & Many-to-1 dengan `poliklinik`	Manajemen dokter dan penjadwalan konsultasi.
poliklinik	`id_poli (PK)`, nama_poli, deskripsi, lokasi_gedung	1-to-Many dengan `dokter`	Kategorisasi poliklinik (Umum, Gigi, Anak, Jantung).
pendaftaran	`id_pendaftaran (PK)`, nomor_antrean, id_pasien (FK), id_dokter (FK), tgl_kunjungan, status	Foreign Key ke `pasien` dan `dokter`	Pelacakan riwayat antrean medis secara kontinu.

4. Audit Keamanan & Analisis Kerentanan Siber

Audit keamanan kode (Static Application Security Testing / SAST manual) menemukan beberapa celah yang perlu dimitigasi sesuai standar **OWASP Top 10** serta **UU Perlindungan Data Pribadi (UU PDP No. 27 Tahun 2022)**.

CELAH 1: SQL Injection (SQLi) — CRITICAL (CVSS: 9.8)

Lokasi: `functions.php` (Fungsi `cari()`, `hapus()`, `tambah()`, `ubah()`)
Analisis: Variabel input langsung dikonkatenasikan ke kueri SQL tanpa Prepared Statements.

Potongan Kode Rentan pada `functions.php`:

```
function cari($keyword){
    $query = "SELECT * FROM datapasien WHERE
              Nama_Pasien LIKE '%$keyword%' OR
              Jenis_Penyakit LIKE '%$keyword%' OR
              Jenis_Kelamin LIKE '%$keyword%'";
    return query($query);
}
```

Vektor Serangan (Exploit PoC): Input pencarian berupa: `' OR '1'='1' --` akan membobol seluruh data pasien seketika. Serangan tingkat lanjut (UNION-based SQLi) berpotensi mengekstraksi seluruh isi skema database.

CELAH 2: Broken Access Control & Ketiadaan Autentikasi — CRITICAL (CVSS: 9.1)

Lokasi: `index.php`, `ubah.php`, `hapus.php`
Analisis: Tidak adanya pengecekan session login. Data rekam medis pasien dapat dibuka, diubah, atau dihapus oleh siapapun di internet.

Implikasi Regulasi: Pelanggaran kerahasiaan rekam medis berpotensi melanggar ketentuan pidana dan perdata dalam UU No. 27 Tahun 2022 tentang Perlindungan Data Pribadi.

CELAH 3: Penghapusan via HTTP GET & Ketiadaan Proteksi CSRF — MEDIUM (CVSS: 6.5)

Lokasi: `hapus.php?id=X`
Analisis: Tindakan destruktif DELETE dapat dieksekusi melalui permintaan HTTP GET tanpa otentikasi token anti-CSRF.

ASPEK POSITIF: Sanitasi Input Menggunakan htmlspecialchars() — GOOD PRACTICE (PARTIAL)

Pengembang telah menerapkan `htmlspecialchars()` pada `tambah()` dan `ubah()` untuk mencegah serangan *Stored Cross-Site Scripting (XSS)*.

5. Blueprint Rekayasa Ulang & Solusi Kode Modern (Bagian 1)

Sebagai langkah mitigasi terhadap celah keamanan yang ditemukan, berikut disajikan implementasi perbaikan menggunakan **PHP Data Objects (PDO)** dengan **Prepared Statements** dan proteksi sesi.

5.1 Koneksi Aman & Singleton PDO (`Database.php`)

```php
<?php
class Database {
    private static ?PDO $instance = null;

    public static function getConnection(): PDO {
        if (self::$instance === null) {
            $dsn = "mysql:host=localhost;dbname=pendaftaran;charset=utf8mb4";
            $options = [
                PDO::ATTR_ERRMODE            => PDO::ERRMODE_EXCEPTION,
                PDO::ATTR_DEFAULT_FETCH_MODE => PDO::FETCH_ASSOC,
                PDO::ATTR_EMULATE_PREPARES   => false, // Menjamin Real Prepared Statements
            ];
            self::$instance = new PDO($dsn, "root", "", $options);
        }
        return self::$instance;
    }
}
?>
```

5.2 Middleware Proteksi Sesi & Token CSRF (`auth_guard.php`)

```php
<?php
session_start();
// Memverifikasi apakah pengguna telah terautentikasi sebagai staf admin
if (!isset($_SESSION['user_id']) || $_SESSION['role'] !== 'admin') {
    header("Location: login.php?error=unauthorized");
    exit;
}

// Pembuatan token CSRF unik per sesi untuk verifikasi form mutasi
if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}
?>
```

> **Prinsip Kerja Parameterized Queries:** Database membedakan secara tegas antara instruksi kueri SQL dengan data input pengguna. Parameter input diperlakukan murni sebagai nilai literal, sehingga payload serangan SQL Injection seperti `' OR 1=1 --` tidak akan pernah dieksekusi sebagai perintah basis data.

5.3 Repository Pasien Anti-SQLi (`PatientRepository.php`)

Pengkapsulan operasi basis data ke dalam kelas repository yang memanfaatkan Prepared Statements secara penuh:

```php
<?php
require_once 'Database.php';

class PatientRepository {
    private PDO $db;

    public function __construct() {
        $this->db = Database::getConnection();
    }

    // Pencarian aman 100% dari celah SQL Injection
    public function search(string $keyword): array {
        $sql = "SELECT * FROM datapasien WHERE Nama_Pasien LIKE :kw1
                OR Jenis_Penyakit LIKE :kw2 OR Jenis_Kelamin LIKE :kw3 ORDER BY id DESC";
        $stmt = $this->db->prepare($sql);
        $term = "%" . $keyword . "%";
        $stmt->execute(['kw1' => $term, 'kw2' => $term, 'kw3' => $term]);
        return $stmt->fetchAll();
    }

    // Penambahan data aman dengan parameterized binding & validasi
    public function create(array $data): bool {
        $sql = "INSERT INTO datapasien (Nama_Pasien, Tempat_dan_Tanggal_Lahir, Jenis_Kelamin,
                Nomor_Telepon, Email, Jenis_Penyakit) VALUES (:nama, :lahir, :gender, :telepon, :email, :penyakit)";
        $stmt = $this->db->prepare($sql);
        return $stmt->execute([
            'nama'     => strip_tags($data['Nama_Pasien']),
            'lahir'    => strip_tags($data['Tempat_dan_Tanggal_Lahir']),
            'gender'   => $data['Jenis_Kelamin'],
            'telepon'  => preg_replace('/[^0-9+-]/', '', $data['Nomor_Telepon']),
            'email'    => filter_var($data['Email'], FILTER_SANITIZE_EMAIL),
            'penyakit' => strip_tags($data['Jenis_Penyakit'])
        ]);
    }

    // Pembaruan data aman dengan binding ID terproteksi
    public function update(int $id, array $data): bool {
        $sql = "UPDATE datapasien SET Nama_Pasien = :nama, Tempat_dan_Tanggal_Lahir = :lahir,
                Jenis_Kelamin = :gender, Nomor_Telepon = :telepon, Email = :email,
                Jenis_Penyakit = :penyakit WHERE id = :id";
        $stmt = $this->db->prepare($sql);
        return $stmt->execute([
            'nama'     => strip_tags($data['Nama_Pasien']),
            'lahir'    => strip_tags($data['Tempat_dan_Tanggal_Lahir']),
            'gender'   => $data['Jenis_Kelamin'],
            'telepon'  => preg_replace('/[^0-9+-]/', '', $data['Nomor_Telepon']),
            'email'    => filter_var($data['Email'], FILTER_SANITIZE_EMAIL),
            'penyakit' => strip_tags($data['Jenis_Penyakit']),
            'id'       => $id
        ]);
    }

    // Penghapusan aman menggunakan parameter binding numerik
    public function delete(int $id): bool {
        $stmt = $this->db->prepare("DELETE FROM datapasien WHERE id = :id");
        return $stmt->execute(['id' => $id]);
    }
}
?>
```

> **Keunggulan Desain Repository:** Logika akses basis data kini terisolasi dari antarmuka presentasi (View), memungkinkan pengujian unit (Unit Testing), serta mempermudah migrasi masa depan ke framework modern seperti Laravel atau Symfony.

6. Peta Jalan Pengembangan (Future Roadmap) & Panduan Karir

Untuk mentransformasikan prototipe pendaftaran rumah sakit ini menjadi sistem informasi rumah sakit (SIMRS) berkelas enterprise, berikut adalah peta jalan strategis bertahap:

6.1 Roadmap Skalabilitas Sistem

Tahapan	Target Milestones	Deliverables & Deskripsi Teknis
Fase 1 (Segera) HARDENING	Refactoring Arsitektur & Keamanan	• Migrasi penuh MySQLi prosedural ke PDO Prepared Statements. • Implementasi Login Multi-Role (Admin, Loket, Pasien) dengan Bcrypt/Argon2. • Penutupan celah penghapusan GET dengan implementasi formulir POST + CSRF Token.
Fase 2 (1-2 Bulan) OTOMASI	Notifikasi & Tiket Antrean PDF	• Integrasi WhatsApp Gateway API (Fonnte/Twilio) untuk kirim nomor antrean digital. • Pembuatan tiket antrean digital format PDF yang dapat diunduh langsung pasien. • Validasi email aktif melalui SMTP server terautentikasi (PHPMailer).
Fase 3 (3-4 Bulan) REAL-TIME	Display Antrean Live Queuing	• Layar Display Antrean Poli berbasis WebSockets / Server-Sent Events (SSE). • Panggilan suara terkomputerisasi (Text-to-Speech) untuk memanggil pasien di ruang tunggu. • Estimasi waktu tunggu otomatis berdasarkan rata-rata durasi dokter.
Fase 4 (Jangka Panjang) ENTERPRISE	Interoperabilitas SATUSEHAT Kemenkes	• Implementasi format data Rekam Medis Elektronik (RME) standar HL7 FHIR. • Bridging API BPJS Kesehatan (Mobile JKN & Antrean Online). • Modul pembayaran terintegrasi (QRIS & Virtual Account).

6.2 Panduan Menjawab Wawancara Teknis (Portfolio Pitching)

Pertanyaan Interview: *"Bisa ceritakan tentang arsitektur proyek RS Online dan tantangan teknis terbesarnya?"*

Jawaban Rekomendasi:
"Proyek RS Online adalah sistem manajemen pendaftaran rumah sakit berbasis PHP dan MySQL yang saya bangun untuk mengefisiensikan antrean pasien tatap muka. Tantangan teknis terbesar adalah merancang alur intake data yang intuitif sekaligus menyediakan pencarian multi-kolom yang cepat bagi staf administrasi. Selain membangun fungsionalitas CRUD yang lengkap, saya juga melakukan audit keamanan mendalam untuk mengidentifikasi celah SQL Injection dan Broken Access Control, serta merumuskan blueprint perbaikan menggunakan PDO Prepared Statements dan arsitektur Role-Based Access Control sesuai regulasi UU Perlindungan Data Pribadi."

Pertanyaan Interview: *"Bagaimana strategi Anda jika aplikasi ini harus menangani lonjakan ribuan antrean secara bersamaan?"*

Jawaban Rekomendasi:
"Strateginya adalah menerapkan pemisahan database ke bentuk 3NF dengan index komposit pada kolom tanggal dan poli, lalu mengimplementasikan message broker asinkron seperti Redis Queue agar request pendaftaran tidak langsung membebani relasional database secara simultan."

7. Kesimpulan & Lembar Verifikasi Portofolio

Proyek **Sistem Informasi & Pendaftaran Pasien RS Online** karya **Yoginara Pratama Sitorus** merepresentasikan fondasi rekayasa perangkat lunak yang fungsional dan terstruktur. Proyek ini mendemonstrasikan penguasaan siklus hidup pengembangan web secara komprehensif: perancangan database relasional, logika backend terpusat, pengolahan form interaktif, serta implementasi antarmuka Bootstrap 5 yang adaptif.

7.1 Matriks Evaluasi Rekayasa Perangkat Lunak

Dimensi Rekayasa	Skor	Evaluasi Ringkas	Rekomendasi Utama
Fungsionalitas CRUD	**8.5 / 10**	Operasi Create, Read, Update, Delete, dan Search berjalan lancar tanpa kendala.	Tambahkan pagination data dan ekspor laporan ke format Excel/PDF.
Desain & Responsivitas UI	**8.0 / 10**	Pemanfaatan Bootstrap 5 terkonfigurasi dengan baik pada desktop dan mobile.	Lengkapi modal feedback dialog modern pengganti default alert JS.
Struktur & Modularitas	**6.5 / 10**	Pengelompokan fungsi ke dalam `functions.php` mempermudah reusabilitas.	Transformasikan fungsi prosedural menjadi kelas OOP berkonsep MVC.
Keamanan Data & Privasi	**5.0 / 10**	Terdapat sanitasi dasar XSS, namun memiliki kerentanan SQLi dan akses tanpa login.	Terapkan PDO Prepared Statements dan Role-Based Access Control secara mutlak.

7.2 Rekomendasi Implementasi Produksi (Production Readiness)

- **Pengamanan Lapisan Basis Data:** Wajib menerapkan koneksi PDO dengan opsi `PDO::ATTR_EMULATE_PREPARES => false` untuk menutup 100% risiko serangan SQL Injection.
- **Implementasi Autentikasi Pengguna:** Membatasi akses dashboard pasien hanya untuk staf medis yang terverifikasi menggunakan token sesi dan hash password aman (Bcrypt/Argon2).
- **Normalisasi Tabel Kunjungan:** Memisahkan identitas permanen pasien dari riwayat kunjungan antrean harian untuk mencegah anomali data.
- **Penyempurnaan Proteksi CSRF:** Seluruh form mutasi (POST) wajib divalidasi dengan token anti-pemalsuan permintaan antar-situs.

PENGEMBANG PERANGKAT LUNAK:

Yoginara Pratama Sitorus

Full-Stack Web Developer | Sistem Informasi Kesehatan

Repository: GitHub / Tugas_Besar

STATUS VERIFIKASI DOKUMEN:

VERIFIED TECHNICAL AUDIT

Dokumen Rekayasa Sistem & Portofolio Resmi

Sistem Informasi & Pendaftaran Pasien Rumah Sakit Online (RS Online)

Hak Cipta (c) 2023 - 2026 Yoginara Pratama Sitorus. Seluruh hak cipta dilindungi undang-undang.